

MAPEO GQM+PRAGMATIC A REQUISITOS NORMATIVOS

Trazabilidad Completa: Objetivo GQM → Pregunta → Métrica FISMA FY2025 → Normativa

Kit GQM+PRAGMATIC FISMA 2025 — Documento (d) • Versión 1.0 • Abril 2026

"La trazabilidad normativa no es burocracia: es la garantía de que cada métrica existe porque alguien, en algún texto con fuerza legal, entendió que esa cosa específica importaba."

TABLA MAESTRA DE TRAZABILIDAD GQM → NORMATIVA

(25 métricas FISMA FY2025 + trazabilidad completa a 4 capas normativas)

ID Métrica	Nombr e Métrica FISMA FY2025	Objetiv o GQM (GOAL)	Pregun ta GQM (QUESTION)	Función CSF 2.0	Score PRAGMATIC /90	Artícul o ENS (RD 311/2022)	Artícul o NIS2 (Dir. 2022/2555)	Refere ncia NIST SP	Eje ENCS España 2025
Gov-1	Cyberse curity Govern ance Progra m	GOAL-I: Gobern anza efectiva con respons abilida d directiv a clara	¿Existe progra ma formal aproba do por la direcció n con política, CISO, comité y KPIs?	GOVER N	70 ★★★ ★☆☆	Art. 13 (Polític a de Segurid ad); Art. 13.2 (Respo nsabili dades)	Art. 20 (Gober nanza directiv a); Art. 21.1 (Medid as de gestión)	NIST CSF 2.0: GV.OC-1, GV.RR-1; NIST SP 800-53: PM-1, PM-2	Eje 4: Marco instituc ional
Gov-2	Leaders hip Accoun tability	GOAL-I: Gobern anza efectiva con respons abilida d directiv a clara	¿En qué medida la direcció n toma decisio nes activas de ciberse guridad con datos y métrica s?	GOVER N	66 ★★★ ☆☆☆	Art. 13.2 (Respo nsabili dad del respons able de segurid ad)	Art. 20.1 (Respo nsabili dad persona l directiv os)	NIST SP 800-53: PM-1, PM-6; NIST CSF 2.0: GV.RR-2	Eje 4: Marco instituc ional
Gov-3	Risk Toleran ce Stateme nt	GOAL-I: Gobern anza efectiva con toleran cia al riesgo definid a	¿Está definid a y comuni cada la toleran cia al riesgo ciberné tico?	GOVER N	67 ★★★ ☆☆☆	Art. 14 (Gestió n de riesgos) ; Art. 5 (Princi pio GBR)	Art. 21.2.a (Análisi s de riesgos y segurid ad de SI)	NIST SP 800-53: RA-2, PM-9; NIST CSF 2.0: GV.RM-3	Eje 4: Marco instituc ional

SCRM-1	C-SCRM Plan and Policy	GOAL-II: Cadena de suministro TIC gestionada y segura	¿Existe inventario actualizado de proveedores críticos con clasificación por nivel de riesgo?	GOVERN	62 ★★★☆☆	Art. 19 (Adquisición de productos y servicios de seguridad)	Art. 21.2.d (Seguridad cadena de suministro; proveedores)	NIST SP 800-161r1: SR-1, SR-2, SR-3; NIST CSF 2.0: GV.SC-3	Eje 5: Capacidades industriales
SCRM-2	Supplier Risk Identification	GOAL-II: Cadena de suministro TIC gestionada y segura	¿Qué % de contratos TIC críticos incluyen cláusulas de ciberseguridad verificables?	GOVERN	62 ★★★☆☆	Art. 19.3 (Condiciones contractuales con terceros)	Art. 21.2.d (Acuerdos contractuales con proveedores)	NIST SP 800-161r1: SR-5, SR-10; NIST CSF 2.0: GV.SC-7	Eje 5: Capacidades industriales
SCRM-3	Supplier Risk Response	GOAL-II: Cadena de suministro TIC gestionada y segura	¿Se evalúa el riesgo cibernético de los proveedores antes de adjudicación y durante el contrato?	GOVERN	65 ★★★☆☆	Art. 19 (Vigilancia del servicio; revisión de proveedores)	Art. 21.2.d (Evaluación y supervisión continua de proveedores)	NIST SP 800-161r1: SR-6, SA-4; NIST CSF 2.0: GV.SC-9	Eje 5: Capacidades industriales

RA-1	Asset Inventory	GOAL-III: Activos identificados y clasificados exhaustivamente	¿Qué % de activos de información están inventariados con atributos completos en CMDB?	IDENTIFY	68 ★★★☆☆	Medida op.exp.1 (Inventario de activos) ; Art. 14 (Gestión de riesgos)	Art. 21.2.a (Gestión de activos como base del análisis de riesgos)	NIST SP 800-53: CM-8, PM-5; NIST CSF 2.0: ID.AM-1	Eje 3: Seguridad del ciberespacio
RA-2	System Categorization	GOAL-III: Sistemas categorizados proporcionalmente al impacto	¿Los sistemas tienen categorización FIPS 199 / ENS vigente, aprobada y revisada?	IDENTIFY	70 ★★★☆☆	Arts. 40-44 RD 311/2022 (Categorización: Básica/Media/Alta)	Art. 21.1 (Proporcionalidad de medidas al nivel de riesgo)	NIST FIPS 199; NIST SP 800-60; NIST CSF 2.0: ID.AM-3	Eje 1: Resiliencia redes y sistemas
RA-3	Risk Assessment	GOAL-III: Riesgos cuantificados y priorizados formalmente	¿Se realiza un AR formales con metodología documentada y frecuencia adecuada por nivel?	IDENTIFY	65 ★★★☆☆	Art. 14 (Gestión de riesgos) ; MAGER IT v3 (recomendado CCN)	Art. 21.2.a (Análisis de riesgos y seguridad de los SI)	NIST SP 800-30 Rev.1; NIST SP 800-39; NIST CSF 2.0: ID.RA-1	Eje 1: Resiliencia

CM-1	Configuration Baselines	GOAL-IV: Superficie de ataque minimizada mediante hardening	¿Qué % de sistemas siguen líneas base de configuración segura aprobadas y verificadas?	PROTECT	69 ★★★☆☆	Medida mp.eq.3 (Seguridad en equipos); op.exp. 5 (Gestión de cambios)	Art. 21.2.e (Seguridad en adquisición, desarrollo y mantenimiento)	NIST SP 800-70; CIS Benchmarks v8; NIST SP 800-53: CM-6, CM-7	Eje 3: Seguridad ciberespacio
CM-2	Patch Management — Critical CVE	GOAL-IV: Vulnerabilidades conocidas remedias en plazos seguros	¿Cuáles el MTTP (tiempo medio de parche) para CVE críticos (CVSS ≥ 9.0 / CISA KEV)?	PROTECT	76 ★★★☆☆	Medida op.exp. 4 (Gestión de parches y actualizaciones)	Art. 21.2.e (Mantenimiento o actualizado de sistemas y redes)	NIST SP 800-40 Rev.4; CISA KEV directive; NIST CSF 2.0: PR.MA-1	Eje 3: Seguridad ciberespacio
CM-3	Vulnerability Scanning Coverage	GOAL-IV: Vulnerabilidades identificadas sistemáticamente	¿Qué % de activos son escaneados con la frecuencia requerida según nivel de criticidad?	PROTECT	72 ★★★☆☆	Medida op.exp. 3 (Gestión de vulnerabilidades y código malicioso)	Art. 21.2.b (Gestión de vulnerabilidades; detección de incidentes)	NIST SP 800-53: RA-5, SI-2; NIST CSF 2.0: ID.RA-1; CISA CDM	Eje 3: Seguridad ciberespacio

IDAM-1	MFA Implem entatio n	GOAL- V: Identid ad verifica da de forma robusta para todos los accesos	¿Qué % de usuario s (privile giados y estánda r) usan MFA para acceso a sistema s corpora tivos?	PROTE CT	77 ★★★ ☆☆	Medida mp.acc. 5 (Autent icación fuerte; doble factor)	Art. 21.2.j (Uso de autenti cación multifa ctor como obligaci ón explícit a)	NIST SP 800- 63B (AAL2/ AAL3); NIST SP 800-53: IA-2, IA-5	Eje 3: Segurid ad ciberes pacio
IDAM-2	Access Review s / Least Privileg e	GOAL- V: Accesos gestion ados bajo principi o de mínimo privileg io	¿Con qué frecuen cia se revisan y certific an los permis os de acceso por respons ables?	PROTE CT	67 ★★★ ☆☆	Medida mp.acc. 2 (Acceso mínimo necesar io); mp.acc. 4 (Contro l de acceso)	Art. 21.2.i (Seguri dad en la gestión y control de acceso)	NIST SP 800-53: AC-2, AC-6; NIST CSF 2.0: PR.AA- 5	Eje 3: Segurid ad ciberes pacio
IDAM-3	Privileg ed Accoun t Manag ement	GOAL- V: Cuentas privileg iadas gestion adas y auditas as centrali zadame nte	¿Existe n control es PAM para todas las cuentas de admini stració n con grabaci ón de sesión?	PROTE CT	71 ★★★ ☆☆	Medida mp.acc. 3 (Contro l de acceso privileg iado); mp.acc. 5	Art. 21.2.i (Acceso privileg iado; control de cuentas de admini stració n)	NIST SP 800-53: AC-17, IA-5, AU-14; NIST CSF 2.0: PR.AA- 5	Eje 3: Segurid ad ciberes pacio

ZTA-S1	Zero Trust Data Management	GOAL-V: Arquitectura Zero Trust implementada en pilar Datos	¿En qué nivel de madurez CISA ZTMM se encuentra la organización en el pilar "Datos"?	PROTECT	59 ★★☆ ☆☆	Art. 14 (Gestión de riesgos emergentes); Principio de defensa en profundidad	Sin mención directa NIS2 (implicito en proporcionalidad Art. 21.1)	NIST SP 800-207 (Zero Trust Architecture); CISA ZTMM v2.0 Pilar Datos	Eje 3: Seguridad ciberespacio
ZTA-S2	Zero Trust Asset Integrity	GOAL-V: Arquitectura Zero Trust implementada en pilar Dispositivos	¿En qué nivel CISA ZTMM se encuentra la organización en el pilar "Dispositivos/Activos"?	DETECT	59 ★★☆ ☆☆	Art. 14 (Riesgos emergentes); Medida op.exp.1 (todos los activos)	Sin mención directa NIS2 (implicito en gestión activos Art. 21.2.a)	NIST SP 800-207; CISA ZTMM v2.0 Pilar Dispositivos; CDM IoT	Eje 3: Seguridad ciberespacio
DP-1	Data Classification & Inventory	GOAL-VI: Datos sensibles identificados, clasificados y protegidos	¿Existe un inventario/mapa de datos completo con clasificación por nivel de sensibilidad?	PROTECT	60 ★★☆ ☆☆	Medida mp.info.3 (Clasificación de la información según ENS)	Art. 21.2.a (Gestión de datos como parte de análisis de riesgos)	NIST SP 800-53: RA-2, MP-1; NIST CSF 2.0: ID.AM-7	Eje 5: Capacidades industriales

DP-2	Encryption Coverage	GOAL-VI: Datos sensibles cifrados en reposo y tránsito	¿Qué % de datos sensibles están cifrados en reposo (AES-256) y en tránsito (TLS 1.3+)?	PROTECT	69 ★★★☆☆	Medida mp.info.3 (Protección de datos); mp.com.2 (Cifrado o comunicaciones)	Art. 21.2.h (Políticas y procedimientos de criptografía y cifrado)	NIST SP 800-175B; FIPS 140-3; FIPS 197 (AES); FIPS 203/204/205 (PQC)	Eje 5: Capacidades industriales
DP-3	DPIA Completion Rate	GOAL-VI: Privacidad evaluada en todos los tratamientos de alto riesgo	¿Se realiza n DPIAs para el 100% de los tratamientos de alto riesgo, actualizadas < 2 años?	PROTECT	62 ★★★☆☆	Art. 11 ENS (Proporcionalidad); coherente con LOPDG DD Arts. 28-29	Art. 21 NIS2 (coherente con RGPD Art. 35 DPIA)	NIST SP 800-53: PT-2, PT-5; ISO/IEC 29134 (DPIA methodology)	Eje 5: Capacidades industriales
ST-1	Security Awareness Training	GOAL-VII: Capital humano capacitado y consciente del riesgo cibernético	¿Qué % de empleados completa anualmente la formación obligatoria en ciberseguridad?	PROTECT	61 ★★★☆☆	Arts. 15-16 RD 311/2022 (Profesionalidad y formación continua)	Art. 20.2 (Formación obligatoria de directivos); Art. 21.2.j (Concienciación)	NIST SP 800-50; NIST NICE Framework; NIST CSF 2.0: PR.AT-1	Eje 2: Capacitación y talento

ST-2	Phishing Simulation Click Rate	GOAL-VII: Comportamiento seguro real o empíricamente	¿Cómo evoluciona la tasa de clics en simulacros de phishing trimestralmente?	PROTECT	68 ★★★☆☆	Art. 16 (Formación práctica en ciberseguridad)	Art. 21.2.j (Formación práctica; cambio de comportamiento)	NIST SP 800-50 (evaluación efectividad formación); NIST SP 800-177	Eje 2: Capacitación y talento
ISCM-1	SIEM Coverage & Log Retention	GOAL-VIII: Todos los activos críticos monitorizados y logs retenidos	¿Qué % de activos críticos envían logs al SIEM con retención ≥ 12 meses (nivel EL3 M-21-31)?	DETECT	69 ★★★☆☆	Art. 24 (Vigilancia continua); Medida op.exp.10 (Registro de actividad)	Art. 21.2.b (Monitorización y logging como control de detección)	NIST SP 800-137; OMB M-21-31 (EL1-EL3); NIST SP 800-92	Eje 1: Resiliencia redes y sistemas
ISCM-2	EDR/XDR Coverage	GOAL-VIII: Detección de amenazas en endpoints con cobertura completa	¿Qué % de endpoints gestionados tienen EDR/XDR activo con firmas < 24h?	DETECT	75 ★★★☆☆	Medida mp.eq.3 + op.exp.3 (Protección de equipos y código malicioso)	Art. 21.2.b (Seguridad de endpoints; detección de incidentes avanzados)	NIST SP 800-53: SI-3, SI-4; NIST CSF 2.0: DE.CM-9	Eje 1: Resiliencia redes y sistemas

ISCM-3	Mean Time to Detect (MTTD)	GOAL-VIII: Detección de amenazas en tiempo mínimo verificado	¿Cuál es el MTTD (días) desde compromiso hasta detección? (media mensual)	DETECT	73 ★★★ ★★☆	Art. 24 (Vigilancia continua proactiva)	Art. 21.2.b (Detección oportuna de incidentes y anomalías)	NIST SP 800-53: SI-4; NIST CSF 2.0: DE.AE-8; MITRE ATT&CK	Eje 1: Resiliencia redes y sistemas
ISCM-4	CTI Consumption & Integration	GOAL-VIII: Inteligencia de amenazas integrada en operaciones de seguridad	¿Consumo la organización CTI de fuentes externas verificadas integradas en el SIEM?	DETECT	56 ★★★ ☆☆☆	Art. 24 (Vigilancia continua; uso de inteligencia de amenazas)	Art. 26.3 NIS2 (Cooperación e intercambio de información sobre amenazas)	NIST SP 800-150; STIX/TAXII (OASIS); NIST CSF 2.0: ID.RA-2	Eje 3: Seguridad ciberespacio
IR-1	Incident Response Plan	GOAL-IX: Respuesta a incidentes preparada y documentada formalmente	¿Existe IRP formal, aprobado < 12 meses, con ≥ 5 escenarios cubiertos?	RESPOND	67 ★★★ ☆☆☆	Art. 25 RD 311/2022 (Respuesta a incidentes; procedimientos)	Art. 21.2.f (Políticas y procedimientos de gestión de incidentes)	NIST SP 800-61r3; NIST SP 800-53: IR-8; NIST CSF 2.0: RS.MA-1	Eje 1: Resiliencia redes y sistemas

IR-2	IR Testing Frequency	GOAL-IX: Capacidades de respuesta probadas y validadas regularmente	¿Con qué frecuencia se prueban las capacidades IR (tabletop + técnico)?	RESPOND	65 ★★★☆☆	Art. 25 (Prueba periódica de planes de respuesta)	Art. 21.2.f (Prueba y evaluación de eficacia de los planes de IR)	NIST SP 800-84; NIST SP 800-53: IR-3; NIST CSF 2.0: RS.MA-1	Eje 1: Resiliencia redes y sistemas
IR-3	MTTC — Mean Time to Contain	GOAL-IX: Incidentes contenidos en plazos que minimizan el impacto	¿Cuáles es el MTTC de incidentes críticos (horas)? Objetivo $\leq 4h$ críticos; $\leq 24h$ altos	RESPOND	72 ★★★☆☆	Art. 25 (Objetivos de eficacia en la respuesta)	Art. 21.2.f (Eficacia y rapidez de la respuesta a incidentes)	NIST SP 800-61r3: sección 3.4; NIST CSF 2.0: RS.MA-4	Eje 1: Resiliencia redes y sistemas
CP-1	Contingency Plan Documentation	GOAL-X: Continuidad operativa garantizada para funciones esenciales	¿Están documentados BCP/DRP con RTO/RPO aprobados < 12 meses para todos los sistemas críticos?	RECOVER	64 ★★★☆☆	Art. 26 (Continuidad de actividad; planes de recuperación)	Art. 21.2.c (Continuidad operativa; copias de seguridad; gestión crisis)	NIST SP 800-34 Rev.1; ISO 22301; NIST CSF 2.0: RC.RP-1	Eje 1: Resiliencia redes y sistemas

CP-2	Contingency Plan Testing	GOAL-X: Planes de continuidad y disponibilidad median te pruebas reales	¿Se prueban los planes con ≥ 1 ejercicio completo/año y $\geq 100\%$ sistemas críticos probados?	RECOVER	65 ★★★☆☆	Art. 26 (Prueba periódica de planes de continuidad)	Art. 21.2.c (Prueba de planes de continuidad y recuperación)	NIST SP 800-34; NIST SP 800-53: CP-4; NIST CSF 2.0: RC.RP-3	Eje 1: Resiliencia redes y sistemas
------	--------------------------	---	---	---------	-------------	---	--	---	-------------------------------------

TABLA DE REFERENCIAS NORMATIVAS CRUZADAS

Artículos ENS (RD 311/2022) → Métricas FISMA cubiertas

Artículo / Medida ENS	Contenido	Métricas FISMA cubiertas	Score PRAGMATIC medio
Art. 5	Principio de gestión basada en riesgos	RA-3, Gov-3	66
Art. 10	Principio de vigilancia continua	ISCM-1/2/3/4	68.3
Art. 13	Política de seguridad	Gov-1, Gov-2	68
Art. 14	Gestión de riesgos	RA-3, Gov-3, ZTA-S1, ZTA-S2	64.5
Arts. 15-16	Profesionalidad y formación	ST-1, ST-2	64.5
Art. 19	Adquisición de productos/servicios	SCRM-1/2/3	63
Art. 24	Vigilancia continua	ISCM-1/2/3/4	68.3
Art. 25	Respuesta a incidentes	IR-1/2/3	68
Art. 26	Continuidad de actividad	CP-1/2	64.5
Arts. 34-36	Auditoría e informes	Gov-1, Gov-2	68
Arts. 40-44	Categorización	RA-2	70
Medida mp.acc.2-5	Controles de acceso	IDAM-1/2/3	71.7
Medida mp.eq.3	Seguridad en equipos	CM-1, ISCM-2	72
Medida mp.info.3	Clasificación información	DP-1, DP-2	64.5
Medida mp.info.9	Copias de seguridad	CP-1, CP-2	64.5
Medida op.exp.1	Inventario de activos	RA-1, ZTA-S2	63.5
Medida op.exp.3	Gestión de código malicioso	CM-3, ISCM-2	73.5
Medida op.exp.4	Gestión de parches	CM-2	76
Medida op.exp.5	Gestión de cambios	CM-1	69
Medida op.exp.10	Registro de actividad	ISCM-1	69

Artículos NIS2 (Directiva 2022/2555) → Métricas FISMA cubiertas

Artículo NIS2	Contenido	Métricas FISMA cubiertas	Score PRAGMATIC medio
Art. 20	Gobernanza: responsabilidad directiva	Gov-1, Gov-2	68
Art. 21.1	Medidas de gestión de riesgos proporcionales	Gov-3, RA-2, RA-3	67.3
Art. 21.2.a	Análisis de riesgos y seguridad de SI	RA-1/2/3, DP-1	65.8
Art. 21.2.b	Gestión de incidentes; detección; logging	ISCM-1/2/3, CM-3	70.8
Art. 21.2.c	Continuidad operativa; BCP; backups	CP-1/2	64.5
Art. 21.2.d	Seguridad cadena de suministro	SCRM-1/2/3	63
Art. 21.2.e	Adquisición, desarrollo y mantenimiento seguro	CM-1, CM-2	72.5
Art. 21.2.f	Políticas y procedimientos IR; eficacia	IR-1/2/3	68
Art. 21.2.g	Ciberhigiene básica y formación	CM-1/2/3, ST-1/2	69.2
Art. 21.2.h	Criptografía y cifrado	DP-2	69
Art. 21.2.i	RRHH; control de acceso; IAM	IDAM-1/2/3	71.7
Art. 21.2.j	MFA (mención explícita)	IDAM-1	77
Art. 21.3	Amenazas emergentes y vulnerabilidades nuevas	ZTA-S1/S2, DP-2	62.3
Art. 23	Notificación de incidentes (<24h/<72h/1mes)	IR-1, IR-3	69.5
Art. 26.3	Intercambio de información sobre amenazas	ISCM-4	56
Art. 29	Redes CSIRT; grupos de cooperación	IR-1, ISCM-4	61.5

Funciones CSF 2.0 → Score PRAGMATIC promedio

Función CSF 2.0	Métricas incluidas	Score medio /90	Métrica más fuerte	Métrica más débil
GOVERN	Gov-1/2/3, SCRM-1/2/3	65.3	Gov-1 (70)	SCRM-1 (62)
IDENTIFY	RA-1/2/3	67.7	RA-2 (70)	RA-3 (65)
PROTECT	CM-1/2/3, IDAM-1/2/3, ZTA-S1/S2, DP-1/2/3, ST-1/2	67.1	IDAM-1 (77)	ZTA-S1/S2 (59)
DETECT	ISCM-1/2/3/4, ZTA-S2	66.4	ISCM-2 (75)	ISCM-4 (56)
RESPOND	IR-1/2/3	68.0	IR-3 (72)	IR-2 (65)
RECOVER	CP-1/2	64.5	CP-2 (65)	CP-1 (64)
Promedio global	25 métricas	66.9	CM-2 / IDAM-1	ZTA-S1/S2 / ISCM-4

TABLA DE UMBRALES DE EFECTIVIDAD FISMA FY2025

(Para uso en el cálculo del IGM y en la herramienta Excel)

ID Métrica	Unidad de medida	Umbral L3 (Mínimo)	Umbral L4 (Efectivo)	Umbral L5 (Optimizado)	Fuente del umbral
Gov-1	Nº elementos formalizados (de 5)	≥ 3/5	≥ 4/5	5/5	CIGIE FY2025 IG FISMA Metrics v2.0
Gov-2	Revisiones/año + % decisiones documentadas	Semestral; ≥50%	Trimestral; ≥80%	Mensual; ≥95%	OMB M-25-04
Gov-3	Existencia + antigüedad + comunicación	Existente; sin fecha	Aprobada <12m; DG	Aprobada <6m; toda org	NIST CSF 2.0: GV.RM
SCRM-1	% proveedores críticos inventariados	≥75%	≥95%	100% + clasificados	NIST SP 800-161r1
SCRM-2	% contratos TIC con cláusulas seguridad	≥50% nuevos	≥90% nuevos; ≥70% vigentes	100% + verificados	NIST SP 800-161r1
SCRM-3	% proveedores alto riesgo con plan respuesta	≥50%	≥75%	100% + revisión continua	NIST SP 800-161r1
RA-1	% activos en CMDB con ≥6 atributos	≥80%	≥95%	100% + automatizado	CISA CDM; NIST SP 800-53: CM-8
RA-2	% sistemas con categorización vigente	≥90%	≥100%	100% + revisión anual	ENS Arts. 40-44; FIPS 199
RA-3	% sistemas con AR formal vigente	≥70%	≥90%	100% + actualización continua	NIST SP 800-30; MAGERIT v3
CM-1	% sistemas con SCB aplicada y verificada	≥80%	≥95%	100% + verificación automatizada	NIST SP 800-70; CIS
CM-2	MTTP CVE críticos (días)	≤ 30 días	≤ 15 días	≤ 7 días (KEV: inmediato)	CISA KEV; NIST SP 800-40 Rev.4
CM-3	% activos escaneados por frecuencia	≥70% críticos/mes	≥95% críticos/semana	100% continuo + automatizado	CISA CDM; NIST RA-5
IDAM-1	% usuarios con MFA activo	≥80% privilegiados	100% privilegiados; ≥90% estándar	100% todos + FIDO2	NIS2 Art. 21.2.j; NIST SP 800-63B

IDAM-2	% cuentas con revisión <6 meses	≥70%	≥90%	100% + revisión continua	NIST SP 800- 53: AC-2
IDAM-3	% cuentas privilegiadas en PAM	≥75%	≥95% + grabación sesiones	100% + Just- in-Time	NIST SP 800- 53: AC-17
ZTA-S1	Nivel CISA ZTMM pilar Datos (1-4)	Nivel 1 (Tradicional)	Nivel 2 (Avanzado)	Nivel 3/4 (Óptimo)	CISA ZTMM v2.0
ZTA-S2	Nivel CISA ZTMM pilar Dispositivos (1-4)	Nivel 1	Nivel 2	Nivel 3/4	CISA ZTMM v2.0
DP-1	% repositorios con clasificación formal	≥70%	≥90%	100% + automatizado con DSPM	NIST SP 800- 53: RA-2
DP-2	% datos sensibles cifrados (reposo + tránsito)	≥80%	≥100% sensibles	100% + PQC en roadmap	NIST FIPS 140- 3; FIPS 197
DP-3	% tratamientos alto riesgo con DPIA vigente	≥75%	≥100%	100% + revisión continua	RGPD Art. 35; ISO/IEC 29134
ST-1	% plantilla con formación anual completada	≥70%	≥90%	100% + formación rol- específica	NIST SP 800- 50; ENS Art. 16
ST-2	Phishing click rate (%)	< 15%	< 5%	< 2% + tendencia descendente	NIST SP 800- 50; benchmarks sectoriales
ISCM-1	% activos críticos con logging (EL3 M-21-31)	≥70% (EL1)	≥90% (EL3; retención ≥12m)	100% (EL4; automatizado)	OMB M-21-31; NIST SP 800- 92
ISCM-2	% endpoints con EDR activo (<24h firmas)	≥80%	≥95%	100% + XDR integrado	NIST SP 800- 53: SI-3; NIST CSF DE.CM
ISCM-3	MTTD (días; mediana mensual)	≤ 30 días	≤ 7 días	≤ 1 día	IBM Cost of Data Breach; NIST benchmark

ISCM-4	Nº fuentes CTI + % alertas enriquecidas	≥1 fuente	≥3 fuentes; ≥30% enriquecidas	≥5 fuentes; ≥60% + ISAC membership	NIST SP 800-150; STIX/TAXII
IR-1	Plan aprobado + antigüedad + escenarios	Existente; ≥3 escenarios	Aprobado <12m; ≥5 escenarios	Aprobado <6m; ≥10 + auto-activación	NIST SP 800-61r3
IR-2	Ejercicios de IR/año (tabletop + técnico)	≥1/año (tabletop)	≥2/año (1 tabletop + 1 técnico)	≥4/año + Red Team integrado	NIST SP 800-84
IR-3	MTTC incidentes críticos (horas)	≤ 24 horas	≤ 4 horas	≤ 1 hora + SOAR automatizado	NIST SP 800-61r3; ENISA CSIRT benchmarks
CP-1	% sistemas críticos con BCP/DRP + RTO/RPO	≥75%	100% + aprobado <12m	100% + prueba exitosa <6m	NIST SP 800-34; ISO 22301
CP-2	Ejercicios continuidad/año + % sistemas probados	≥1/año; ≥50% críticos	≥1/año; 100% críticos	≥2/año; 100% + DR automatizado	NIST SP 800-34; NIST SP 800-53: CP-4

Kit GQM+PRAGMATIC FISMA 2025 — Mapeo Normativo · Versión 1.0 · Abril 2026

Fuentes: FY2025 IG FISMA Reporting Metrics v2.0 (CIGIE/OMB, 3 abril 2025); OMB M-25-04 (enero 2025); NIST CSF 2.0 (febrero 2024); RD 311/2022 ENS; Directiva UE 2022/2555 (NIS2); ENCS España 2025; NIST SP 800-53 Rev.5; Basili et al. GQM+Strategies (2014); Brotby & Hinson PRAGMATIC (2013)